

Question 1: Identification & Prioritization of Vulnerabilities After Port Scanning

- **Identification & Analysis:**

- **Service & Version Enumeration:** Perform banner grabbing and service version detection (e.g., `nmap -sV`) to identify specific software titles and version numbers running on open ports.

PDF

- **Vulnerability Mapping:** Cross-reference identified services against CVE databases (NVD, Exploit-DB, VulnDB) or run automated vulnerability scripts (e.g., `nmap --script vuln`, Nessus, OpenVAS).
- **OS & Contextual Identification:** Determine target operating system details and system roles (e.g., web server vs. database host) to evaluate context.

- **Prioritization Strategy:**

- **CVSS Score & Exploitability:** Prioritize vulnerabilities based on Common Vulnerability Scoring System (CVSS v3/v4) ratings, focusing first on Critical/High risks with publicly available remote code execution (RCE) exploits.
- **Asset Criticality & Business Impact:** Rank systems according to business impact—data stores, primary domain controllers, and exposed web interfaces take higher priority over non-critical endpoints.
- **Exposure Level:** Directly internet-facing open services take precedence over internally isolated services.

Question 2: Discrepancies Between SYN Scan and TCP Connect Scan

- **Causative Factors:**

- **Firewalls & Stateful Inspection:** Stateful firewalls or IDS/IPS devices may allow full TCP handshakes (TCP Connect) while dropping or blocking incomplete/half-open handshakes (SYN scan) as suspicious behavior.
- **Privilege Restrictions & OS Stack:** SYN scans construct raw packets requiring administrative/root privileges; unprivileged execution defaults to TCP Connect, which relies on the underlying OS system socket calls (`connect()`).
- **Application-Level Proxies / Port Knocking:** Intermediate proxy systems, load balancers, or active defense mechanisms (e.g., Synkill, port knocking) might acknowledge full TCP connections on behalf of backend services while dropping SYN attempts.

- **Verification Methods:**

- **Packet Capture Analysis:** Run `tcpdump` or Wireshark to monitor raw packet responses (e.g., SYN-ACK, RST, or packet drops) during both scan types.
- **Targeted Banner Grabbing / Manual Connection:** Use tools like `nc` (Netcat) or `telnet` to establish a direct connection and observe full application responses.
- **Alternative Scan Modes:** Execute ACK (`-sA`) or FIN/NULL/Xmas scans (`-sF`, `-sN`, `-sX`) to determine firewall rule states and confirm open vs. filtered status.

Question 3: Filtered Ports & Evasion/Information Gathering Techniques

- **Responsible Security Mechanisms:**

- **Packet-Filtering Firewalls:** Rule bases configured to drop incoming packets (returning no response) rather than actively rejecting them.
- **Intrusion Detection/Prevention Systems (IDS/IPS):** Automated rule sets configured to block or drop probe traffic upon detecting port scanning patterns.
- **Network Access Control Lists (ACLs) & Host-Based Firewalls:** Routers, cloud security groups, or OS firewalls (e.g., `iptables`, Windows Firewall) silently discarding incoming traffic.

- **Information Gathering Techniques:**

- **Evasion & Fragment Scanning:** Use packet fragmentation (`nmap -f`) or adjust MTU sizes to bypass simplistic signature-based IDS devices.
- **Decoy & Spoofing Techniques:** Utilize decoy IPs (`nmap -D`) or modify source ports (`nmap --source-port 53`) to blend in with trusted traffic such as DNS or HTTP.
- **UDP/ICMP Sweeps & Idle Scanning:** Conduct IP Protocol scans, ICMP timestamp/address mask requests, or Zombie/Idle scans (`nmap -sI`) to map firewalled hosts indirectly.

Question 4: Comparison of TCP, UDP, and SYN Port Scanning Techniques

Scan Technique	Primary Scenarios	Key Advantages	Core Limitations
TCP Connect (-sT) PDF	Unprivileged environments; modern user endpoints without root access.	Reliable, does not require raw socket privileges, accurate application response.	Easily logged by target systems; slower due to full 3-way handshake completion.
Stealth SYN (-sS) PDF	Default discovery scan; authorized pentests requiring fast, low-footprint scanning.	Fast, rarely logged by basic application logs, efficiently scans large subnet ranges.	Requires elevated privileges (root/admin); easily detected by modern stateful firewalls/IDS.
UDP Scan (-sU) PDF	Auditing critical infrastructure services (DNS, SNMP, DHCP, NTP, VoIP).	Discovers non-TCP services essential for full security posture assessment.	Extremely slow due to OS ICMP rate-limiting; high rate of open filtered ambiguity.

Question 5: Risk Assessment and Mitigation for Exposed Critical Services

- **Risk Assessment:**
 - **SSH (Port 22):** High risk of brute-force password attacks, credential stuffing, and unauthorized administrative access if outdated or misconfigured.
 - **FTP (Port 21):** Severe risk of cleartext credential sniffing, anonymous upload/download access, or arbitrary file modification.
 - **Database Ports (e.g., 3306 MySQL, 1433 MSSQL, 5432 Postgres):** Critical risk of direct data exfiltration, database corruption, SQL injection, or full host compromise via DB extensions.
- **Recommended Mitigation Strategies:**
 - **Access Control & Network Isolation:** Remove direct internet exposure; place database and administrative services behind a corporate VPN, Zero Trust Network Access (ZTNA), or restrict access via strict IP Whitelisting.
 - **Service Hardening:** Enforce key-based authentication (disabling password authentication for SSH), disable anonymous FTP (or upgrade to SFTP/FTPS), and disable default/sa database accounts.
 - **Patching & Segmentation:** Update all exposed services to the latest stable versions, enforce strong network segmentation (VLANs/subnets), and configure host-based firewalls to restrict inbound connections to trusted management subnets only.

Section 1: Technical Deep-Dive & Advanced Concepts

Advanced Scanning & Protocol Mechanics

- **TCP Null, FIN, and Xmas Scans (-sN, -sF, -sX):** These non-standard stealth scans exploit a loophole in RFC 793 TCP implementations.
 - Open ports drop incoming probes without sending a response, resulting in an open|filtered state.
 - Closed ports respond with a RST (Reset) packet.
 - *Limitation:* Modern stateful firewalls or systems non-compliant with RFC 793 (e.g., Windows operating systems) send RST packets for all probe types, rendering these scans ineffective against them.
- **ACK Scan (-sA):** Used strictly to map out firewall rule sets rather than determining port states.
 - Returns RST for both open and closed ports if traffic is unfiltered.
 - Returns no response (or ICMP unreachable) if blocked, marking the port as filtered.

Advanced Firewall Evasion Mechanics

- **Source Port Manipulation (--source-port 53 / -g):** Exploits legacy firewall configurations that inherently trust inbound traffic originating from well-known service ports (e.g., DNS port 53 or HTTP port 80).
- **IP Packet Fragmentation (-f, --mtu):** Splits the TCP header across multiple tiny packet fragments. Simple signature-based Intrusion Detection Systems (IDS) that fail to reassemble packets in memory miss the inspectable TCP signatures.
- **Decoy Scanning (-D):** Mixes real IP traffic with active decoy IP addresses so target intrusion monitoring tools cannot easily distinguish the real scanning host.

Section 2: Command Reference Sheet for Assessment Implementation

Category	Nmap Command Flag	Practical Purpose / Use Case
Service Enumeration	nmap -sV --version-intensity 5	Forces intense banner probing to accurately identify service versions.
Vulnerability Assessment	nmap --script vuln	Runs standard Nmap Scripting Engine (NSE) modules to detect known vulnerabilities.
Fast Discovery Scan	nmap -sS -F --top-ports 100	Rapid stealth scan targeting the top 100 most critical ports.
Firewall Rule Evasion	nmap -sS -Pn -f -D RND:5	Disables host ping, fragments packets, and uses 5 decoy IPs to bypass detection.
UDP Service Probing	nmap -sU -sV -p 53,67,123,161	Audits high-risk UDP infrastructure ports (DNS, DHCP, NTP, SNMP).
Full Range Inspection	nmap -p- -T4	Scans all 65,535 TCP ports at a balanced, aggressive speed.

Section 3: Practical Remediation Workflow for Identified Risks

[Discovery] —————▶ [Isolation] —————▶ [Hardening] —————▶ [Verification]

Open Ports Place behind VPN Disable Plaintext Re-scan with Nmap
(21, 22, 3306) / Network FW & Enforce MFA Confirm Ports Closed

- 1. **Immediate Boundary Isolation:** Restrict external access to database ports (e.g., 3306, 5432, 1433) and remote management interfaces (e.g., SSH, RDP) using strict security groups, access control lists (ACLs), or Zero Trust Network Access (ZTNA).
- 2. **Protocol Modernization:** Transition from unencrypted legacy protocols to secure alternatives (e.g., replace FTP with SFTP/SCP; replace HTTP with HTTPS).
- 3. **Authentication Hardening:** Require multi-factor authentication (MFA) and explicit public key authentication for SSH (disabling password authentication in sshd_config).
- 4. **Continuous Posture Auditing:** Schedule automated scanning routines using Nmap or vulnerability management tools to detect newly exposed or unpatched services.

Service-Specific Enumeration Strategies

- **SMB/NetBIOS (Ports 139 / 445):**
 - Execute OS fingerprinting, share enumeration, and user listing (e.g., using enum4linux, smbclient, or nmap --script smb-enum-shares,smb-enum-users).
 - Verify security configurations for guest account access, null sessions, and legacy protocol vulnerabilities like SMBv1 (e.g., MS17-010 / EternalBlue).

- **SNMP (Ports 161 / 162 UDP):**

- Conduct community string brute-forcing (public, private) using tools like snmpwalk or onesixtyone.
- Extract system metrics, network interfaces, routing tables, and installed software details via Management Information Base (MIB) queries.

- **DNS (Port 53):**

- Attempt Zone Transfers (AXFR requests) to download entire DNS domain mapping tables.
- Execute record enumeration (A, AAAA, MX, TXT, NS) and dictionary-based subdomain brute-forcing (dns-brute / gobuster).

Nmap Scripting Engine (NSE) Script Categories

- **default (-sC):** Executes safe, fast, and highly reliable scripts for banner grabbing and essential service detection without crashing target hosts.
- **vuln:** Probes open services specifically for documented vulnerabilities and CVEs (e.g., Shellshock, Heartbleed, EternalBlue).
- **auth & brute:** Detects authentication bypass points and performs automated credential testing against exposed services.
- **intrusive / exploit:** Conducts high-risk probes and active exploitation checks; should be reserved exclusively for explicitly authorized, controlled assessments.

Post-Scanning Enterprise Remediation Standard

[Scan Detection] —► [Emergency Isolation] —► [Configuration Hardening] —► [Defensive Logging]

Target Exposed	VLANs & Cloud SGs	Disable Plaintext Protocols	SIEM Integration
(SSH, FTP, DB)	Inbound Block Rules	Require Keys / MFA / SSL	Ingest IDS/IPS Alerts

- **Network-Level Segregation:** Enforce strict micro-segmentation; restrict direct exposure of internal endpoints, management interfaces, and databases using firewalls or Zero Trust Network Access (ZTNA).

- **Identity & Access Management:** Enforce multi-factor authentication (MFA) across all remote access services, disable default accounts, and eliminate plain-text protocols (migrate FTP to SFTP, HTTP to HTTPS).
- **Continuous Monitoring:** Ingest host firewall and network IDS/IPS logs into a Centralized SIEM to flag port sweep patterns, SYN flood events, and unauthorized connection attempts in real time.